Lab 5: Static Code Analysis

Table: Identified Issues and Fixes

No.	Issue	Type	Original Line(s)	Description	Fix Approach
1	Mutable default argument	Bug	11	The `addDevice()` function used an empty dictionary `{}` as a default argument, which could lead to shared mutable state across function calls.	Replaced the default value with `None` and initialized a new dictionary inside the function.
2	Missing module docstring	Code Quality	1	The Python module did not have a module-level docstring explaining its purpose.	Added a module docstring describing the smart-home device hub.
3	Missing function docstrings	Code Quality	11, 16, 23, 32, 36, 40, 45, 49, 54	Several functions did not contain docstrings explaining their purpose.	Added descriptive docstrings to the functions.
4	Inconsistent naming conventions	Style	11, 16, 23, 32, 36, 40, 45, 49	Function names and arguments used camelCase instead of Python's recommended snake_case convention.	Renamed functions and arguments using snake_case and updated their calls.
5	Inconsistent return statements	Code Quality	16	The `toggleDevice()` function had inconsistent return statements.	Updated the function to return a Boolean value consistently.
6	Unspecified file encoding	Code Quality	41	The `open()` function did not explicitly specify a file encoding.	Added `encoding="utf-8"` when opening the JSON state file.
7	Hardcoded network binding	Security	4	The hub used `0.0.0.0`, which can expose a service on all network interfaces.	Changed the host to `127.0.0.1` to restrict access to the local machine.
8	Hardcoded password	Security	7	A password was embedded directly in the source code.	Replaced the hardcoded password with an environment variable named `SMART_HOME_PASSWORD`.
9	Unsafe subprocess execution	Security	51	The scene helper used `subprocess.call()` with `shell=True`,	Removed the subprocess-based scene execution helper.

				creating a potential command-injection risk.	
10	Formatting violations	Style	6, 40, 66, 68	Flake8 reported whitespace before a colon, insufficient blank lines, incorrect inline-comment spacing, and an overlong line.	Corrected spacing, blank lines, comments, and line length to comply with Python style conventions.

1. What is static code analysis?

Static code analysis examines source code without executing it to identify potential bugs, security vulnerabilities, and coding-style violations.

2. What did Pylint identify?

Pylint identified missing docstrings, inconsistent naming, a mutable default argument, unspecified file encoding, and inconsistent return statements.

3. What did Bandit identify?

Bandit identified potentially unsafe network binding, a hardcoded password, and risks associated with subprocess execution.

4. What did Flake8 identify?

Flake8 identified whitespace, blank-line, inline-comment spacing, and line-length violations.

5. What did you learn?

Using multiple static analysis tools helped identify different categories of problems. Fixing the findings improved code readability, maintainability, and security.

Repo Link :
https://github.com/Vishwajeet-dev62/L5_36_smart_home